

## **TITLE:**

# **Detection and Investigation of Brute-Force Authentication Activity Using Splunk (Windows Security Logs)**

## **1. Objective**

The objective of this project is to simulate a real world Security Operations Center (SOC) workflow by detecting and investigating suspicious authentication activity within Windows Security logs using Splunk. The project focuses on identifying brute-force login attempts by analyzing repeated failed authentication events (Event ID 4625) within a short time frame. Upon detection, the investigation is extended to correlate additional events, including successful logins (Event ID 4624), explicit credential usage (Event ID 4648), and process creation activity (Event ID 4688). Due to the unstructured format of the ingested logs, regular expressions (rex) are used to extract key fields required for analysis. The goal is to demonstrate both detection engineering and incident investigation skills in a manner consistent with real SOC operations.

## **2. Tools & Technologies:**

Splunk - Log analysis and alerting platform

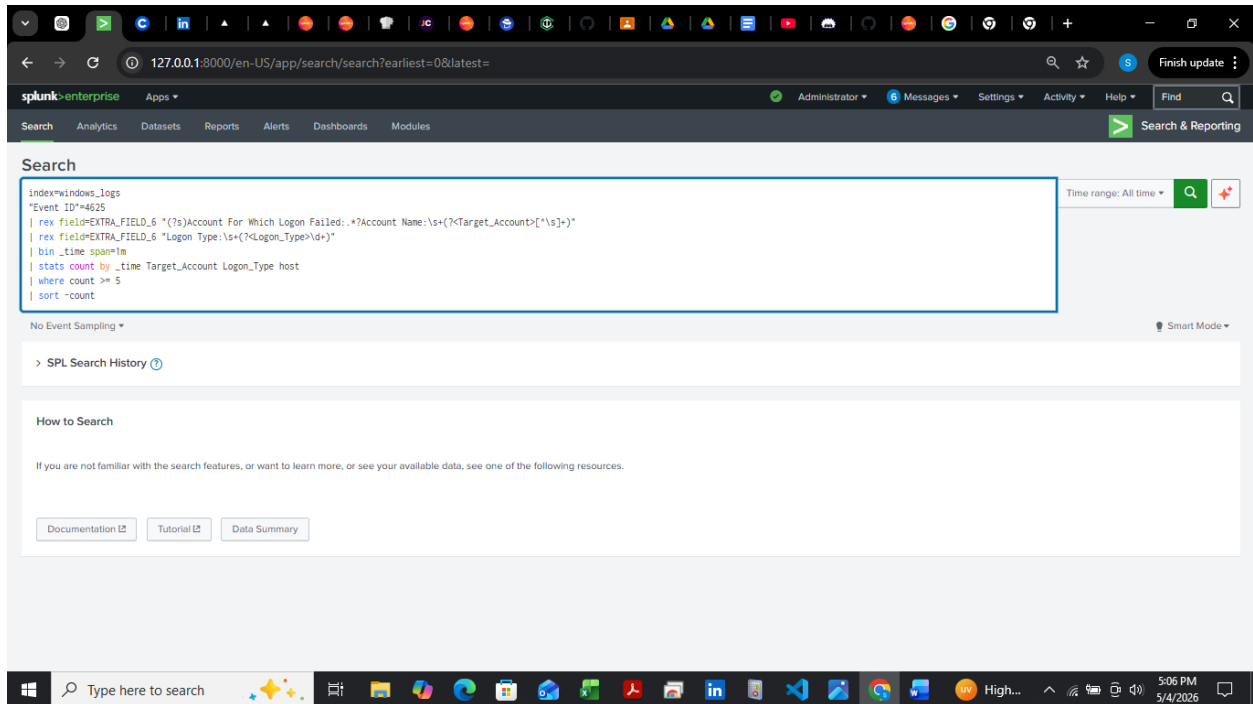
SPL (Search Processing Language) - Query development

Regex (rex command) - Field extraction from unstructured logs

Windows Security Event Logs - Source of authentication and process activity

**Note:** The logs were ingested in CSV format, which required manual field extraction due to improper parsing of structured event data.

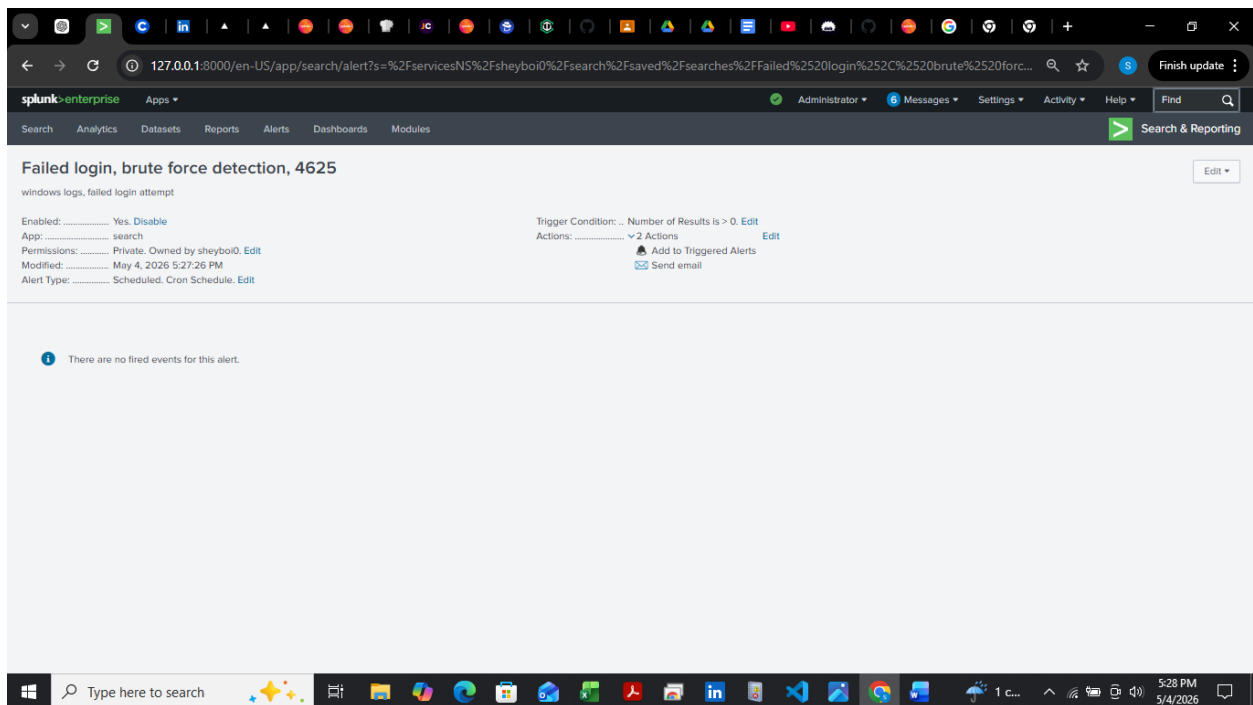
## 4. Detection Engineering: Brute-Force Alert



An alert was configured in Splunk to automatically detect multiple failed login attempts using Event ID 4625. Due to the unstructured nature of the logs, the rex command was used to extract critical fields such as the targeted account and logon type from the raw event data. A time based aggregation (1 minute window) was implemented using the bin command, and the stats function was used to count the number of failed attempts per account.

The alert was configured to trigger when five or more failed login attempts were detected within a one minute interval. The trigger condition was set to "For each result" to ensure that each affected account generates a separate alert. This automated detection mechanism simulates a real-world SOC environment where alerts are generated based on defined thresholds and patterns rather than manual observation.

## Alert Implementation:



The detection query was saved as a scheduled alert in Splunk to enable continuous monitoring. The alert was configured to run at regular intervals and trigger whenever the defined threshold condition was met.

This ensures that suspicious authentication activity is automatically flagged without requiring manual log review.

## Alert Triggered:

The screenshot shows the Splunk Enterprise web interface. The top navigation bar includes the Splunk logo, user 'Administrator', and links for Messages, Settings, Activity, and Help. The main heading is 'Triggered Alerts'. Below it, there's a filter section with a search bar and dropdowns for App (Search & Report...), Owner (All owners), Severity (All severity), and Alert name (All alerts). The results show 1 - 4 of 4 results. The table lists four triggered alerts, all with a severity of 'High' and mode of 'Digest'. Each alert entry includes a checkbox, a time stamp, the alert name, the app, type, severity, mode, and actions (View Results, Edit Alert, Delete).

|                          | Time                                                | Alert name                                | App    | Type      | Severity | Mode   | Actions                                                                            |
|--------------------------|-----------------------------------------------------|-------------------------------------------|--------|-----------|----------|--------|------------------------------------------------------------------------------------|
| <input type="checkbox"/> | 2026-05-04 17:31:37 W. Central Africa Standard Time | Failed login, brute force detection, 4625 | search | Scheduled | High     | Digest | <a href="#">View Results</a>   <a href="#">Edit Alert</a>   <a href="#">Delete</a> |
| <input type="checkbox"/> | 2026-05-04 17:31:03 W. Central Africa Standard Time | Failed login, brute force detection, 4625 | search | Scheduled | High     | Digest | <a href="#">View Results</a>   <a href="#">Edit Alert</a>   <a href="#">Delete</a> |
| <input type="checkbox"/> | 2026-05-04 17:29:27 W. Central Africa Standard Time | Failed login, brute force detection, 4625 | search | Scheduled | High     | Digest | <a href="#">View Results</a>   <a href="#">Edit Alert</a>   <a href="#">Delete</a> |
| <input type="checkbox"/> | 2026-05-04 17:28:29 W. Central Africa Standard Time | Failed login, brute force detection, 4625 | search | Scheduled | High     | Digest | <a href="#">View Results</a>   <a href="#">Edit Alert</a>   <a href="#">Delete</a> |

## Alert Result:

The screenshot shows the Splunk Enterprise web interface with the 'New Search' panel. The search query is: `index=windows_logs "Event ID"=4625 | rex field=EXTRA_FIELD_6 "(?i)Account For Which Logon Failed:.*?Account Name:\s+(?<Target_Account>[^\s]+)" | rex field=EXTRA_FIELD_6 "Logon Type:\s+(?<Logon_Type>[^\s]+)" | bin _time span=1m | stats count by _time Target_Account Logon_Type host | where count >= 3`. The results show 5 events from 5/21/21 9:43:07.000 PM to 5/4/26 5:31:00.000 PM. The table displays the search results with columns for \_time, Target\_Account, Logon\_Type, host, and count.

| _time               | Target_Account    | Logon_Type | host              | count |
|---------------------|-------------------|------------|-------------------|-------|
| 2021-05-21 21:43:00 | admmig@offsec.lan |            | 8 DESKTOP-26A9125 | 5     |

The detection rule identified multiple failed login attempts targeting the account [admmig@offsec.lan](#). A total of five failed authentication attempts were observed within a one minute window on the host

DESKTOP-26A9125. The activity was associated with Logon Type 8, indicating network-based authentication attempts. This pattern is consistent with brute-force or password spraying techniques commonly used to gain unauthorized access. This alert serves as the starting point for further investigation into potential account compromise.

## Step 2

### INVESTIGATION: CHECKING FOR SUCCESSFUL LOGIN

Following the detection of multiple failed login attempts, the next step is to determine whether the attacker was able to successfully authenticate into the system.

This is done by analyzing Event ID 4624 (successful logon events) and correlating them with the previously identified target account.

The screenshot shows the Splunk Enterprise Search interface. The search bar contains the following query:

```
index=windows_logs
"Event ID=4624"
| rex field=EXTRA_FIELD_6 "(?s)New Logon:.*Account Name:.*(?<Account_Name>[^\s]+)"
| rex field=EXTRA_FIELD_6 "Logon Type:.*(?<Logon_Type>\d+)"
| search Account_Name="admmig"
| table _time Account_Name "Event ID" Logon_Type host
| sort _time
```

The search results show one event (before 5/4/26 7:38:09.000 PM) with the following details:

| _time               | Account_Name | Event ID | Logon_Type | host            |
|---------------------|--------------|----------|------------|-----------------|
| 2021-05-21 21:43:18 | admmig       | 4624     | 3          | DESKTOP-26A9125 |

Analysis of Event ID 4624 (successful logon) confirmed that the account *admmig* successfully authenticated shortly after the sequence of failed login attempts. This indicates that the attacker was able to obtain or correctly guess the valid credentials after repeated attempts.

Further examination showed that the successful authentication was associated with **Logon Type 3**, which represents a network-based logon. This type of logon typically occurs when a user accesses a system remotely over the network (e.g., via services like SMB or SSH). In this context, it suggests that the attacker gained access to the system remotely rather than through local interactive logon.

Based on these findings, the incident is escalated from a suspected brute-force attempt to a confirmed account compromise, requiring further investigation into post-authentication activity.

### STEP 3

#### INVESTIGATION (EVENT ID 4648)

Following confirmation of a successful login, the next step is to determine whether the compromised account was used to authenticate to other systems or services using explicit credentials.

This is achieved by analyzing Event ID 4648, which logs instances where a user attempts to log on using explicitly provided credentials. This activity is often associated with lateral movement or credential abuse after initial access.

The screenshot shows the Splunk Enterprise web interface. The search bar contains the following query:

```
index=windows_logs
"Event ID=4648
| rex field=EXTRA_FIELD_6 "(?i)Account Whose Credentials Were Used:.*?Account Name:(?<Account_Name>[^\s]+)"
| rex field=EXTRA_FIELD_6 "Target Server Name:(?<Target_Server>[^\s]+)"
| search Account_Name="admmig"
| table _time "Event ID" Account_Name Target_Server host
| sort _time
```

The search results show 1 event (before 5/5/26 11:57:31.000 AM). The results table is as follows:

| _time               | Event ID | Account_Name | Target_Server | host            |
|---------------------|----------|--------------|---------------|-----------------|
| 2021-05-21 21:43:18 | 4648     | admmig       | localhost     | DESKTOP-26A9125 |

Following the confirmation of a successful login, further investigation was conducted using Event ID 4648 to determine whether the compromised account was used for additional authentication activities. The analysis revealed that the account *admmig* was involved in explicit credential usage shortly after the successful login event. Event ID 4648 indicates that credentials were manually supplied to access a system or service, which is commonly associated with post-authentication activity.

The results showed that the target server was identified as *localhost*, indicating that the credential usage occurred on the same host rather than across different systems. This suggests that the attacker focused on internal system activity instead of performing lateral movement at this stage.

The screenshot shows the Splunk Enterprise interface. The search bar contains the query: `index=windows_logs ("Event ID"=4624 OR "Event ID"=4648) | rex field=EXTRA_FIELD_6 "(?s)(New Logon|Account Whose Credentials Were Used):.*?Account Name:\s*(?<Account_Name>[^\s]+)" | search Account_Name="adminig" | table _time "Event ID" Account_Name host | sort _time`. The results table displays two events, both with Event ID 4648 and Account Name 'adminig', from the host 'DESKTOP-26A9125' at the timestamp '2021-05-21 21:43:18'.

| _time               | Event ID | Account_Name | host            |
|---------------------|----------|--------------|-----------------|
| 2021-05-21 21:43:18 | 4648     | adminig      | DESKTOP-26A9125 |
| 2021-05-21 21:43:18 | 4624     | adminig      | DESKTOP-26A9125 |

Overall, this behavior is consistent with post-exploitation activity, where an attacker, after gaining initial access, begins to utilize valid credentials to operate within the compromised environment.

## STEP 4

### Process Creation (4688)

The screenshot shows the Splunk Enterprise web interface. The search bar contains a query for Event ID 4688. The search results are displayed in a table with columns: \_time, Event ID, Process\_Name, Parent\_Process, Command\_Line, and host. Two results are shown, both for Event ID 4688, occurring on 2021-05-21 at 21:43:07. The first result shows the process sshd.exe creating a new process. The second result shows the process sshd.exe creating a new process with the -R flag, which is associated with remote port forwarding.

```
index=windows_logs
"Event ID"=4688
| rex field=EXTRA_FIELD_6 "New Process Name:\s+(?<Process_Name>[^\n\r]+)"
| rex field=EXTRA_FIELD_6 "Creator Process Name:\s+(?<Parent_Process>[^\n\r]+)"
| rex field=EXTRA_FIELD_6 "Process Command Line:\s+(?<Command_Line>[^\n\r]+)"
| table _time "Event ID" Process_Name Parent_Process Command_Line host
| sort _time
```

| _time               | Event ID | Process_Name                            | Parent_Process                          | Command_Line                                 | host            |
|---------------------|----------|-----------------------------------------|-----------------------------------------|----------------------------------------------|-----------------|
| 2021-05-21 21:43:07 | 4688     | C:\Program Files\OpenSSH-Win64\sshd.exe | C:\Program Files\OpenSSH-Win64\sshd.exe | "C:\Program Files\OpenSSH-Win64\sshd.exe" -y | DESKTOP-26A9125 |
| 2021-05-21 21:43:07 | 4688     | C:\Program Files\OpenSSH-Win64\sshd.exe | C:\Program Files\OpenSSH-Win64\sshd.exe | "C:\Program Files\OpenSSH-Win64\sshd.exe" -R | DESKTOP-26A9125 |

Event ID 4688 shows that the process *sshd.exe* was responsible for creating new processes on the system. While this is a legitimate service, it is directly linked to the earlier authentication activity observed.

The command line includes the *-R* flag, which is associated with remote port forwarding. This can be used to establish tunneled connections and may indicate an attempt to maintain access or create a covert communication channel.

Although the process itself is not inherently malicious, its presence following a successful login and credential usage makes the activity suspicious and indicative of post-compromise behavior.



## Correlated Timeline (4624 - 4648 - 4688)

The screenshot displays the Splunk Enterprise search interface. The search bar contains the following query:

```
index=windows_logs  
("Event ID"=4624 OR "Event ID"=4648 OR "Event ID"=4688)  
| rex field=EXTRA_FIELD_6 "(?s)(New Logon)Account Whose Credentials Were Used):.*?Account Name:.*?(?<Account Name>[^\s]+)"  
| table _time "Event ID" Account_Name host  
| sort _time
```

The search results show 6 events. The table below represents the data displayed in the search results:

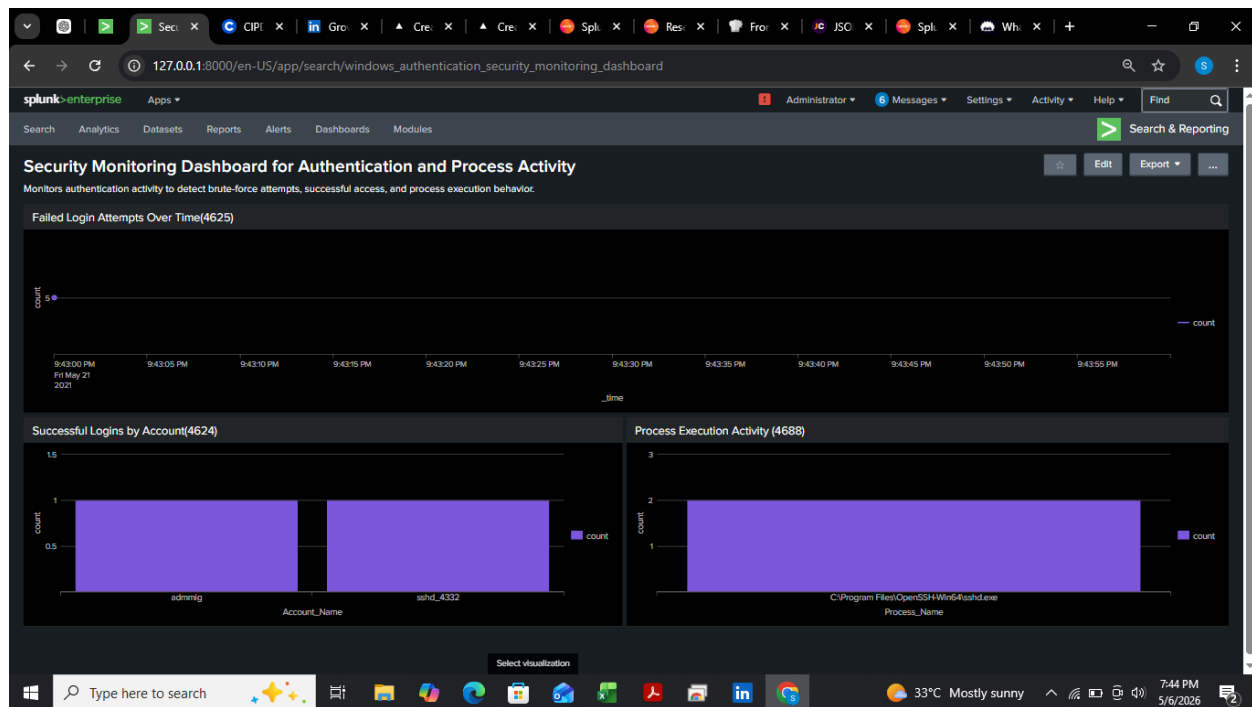
| _time               | Event ID | Account_Name | host            |
|---------------------|----------|--------------|-----------------|
| 2021-05-21 21:43:07 | 4648     | sshd_4332    | DESKTOP-26A9125 |
| 2021-05-21 21:43:07 | 4624     | sshd_4332    | DESKTOP-26A9125 |
| 2021-05-21 21:43:07 | 4688     |              | DESKTOP-26A9125 |
| 2021-05-21 21:43:07 | 4688     |              | DESKTOP-26A9125 |
| 2021-05-21 21:43:18 | 4648     | admiig       | DESKTOP-26A9125 |
| 2021-05-21 21:43:18 | 4624     | admiig       | DESKTOP-26A9125 |

The timeline shows a clear sequence of events starting with a successful login (4624), followed by explicit credential usage (4648), and subsequent process execution (4688).

This progression demonstrates that after gaining access, the attacker used the compromised account to perform further actions within the system. The inclusion of process creation events confirms that activity was executed post-authentication.

This correlation provides strong evidence of a successful intrusion and highlights the transition from initial access to active system interaction.

## Dashboard:



A Splunk dashboard was created to visualize authentication and process activity. It highlights failed login trends, successful user access, and process execution, enabling quick identification of suspicious behavior and supporting efficient security monitoring.

## Conclusion

This investigation identified a clear sequence of events indicating a successful brute force attack and subsequent system activity. Multiple failed login attempts (Event ID 4625) were followed by a successful authentication (Event ID 4624) for the account *admmig*, confirming that valid credentials were eventually obtained. The successful login was performed using Logon Type 3, indicating remote network access.

Further analysis revealed the use of explicit credentials (Event ID 4648), demonstrating that the compromised account was actively used after initial access. Although the activity was limited to the local host, it indicates post authentication interaction within the system.

Process creation events (Event ID 4688) showed the execution of *sshd.exe*, including the use of the *-R* flag, which is associated with remote port forwarding. This behavior suggests potential tunneling activity and an attempt to maintain or extend access. By correlating authentication, credential usage, and process execution events, a complete attack chain was established. The findings confirm that the

attacker successfully gained access and performed actions within the system, representing a confirmed security incident.

### **Recommendation**

- 1.** Implement an Account Lockout Policy to automatically disable user accounts after a defined number of failed login attempts (e.g., 5 attempts), in order to prevent brute-force attacks and reduce the risk of unauthorized access.
- 2.** Restrict or monitor SSH access to critical systems

**Author: Mohammed Ndagi, Date: may 2026.**